

Id	AUDIT-2026-10-07-MyTradingBox	Date	2026-10-07
Type	audit	Status	open
Repo	MyTradingBox	Author	Claude
Stack	angular	Findings	critical: 1, high: 2, medium: 3, low: 9

MyTradingBox code audit — 2026-10-07

Summary

This is the third audit of MyTradingBox. The first two were on 2026-10-06 (audit/AUDIT-REPORT_2026-10-06_1217.md and _1352.md). It covers the 17 commits since 7ca4e17 and re-checks every finding still open from yesterday.

The build is in good shape:

- 928 tests pass.
- Lint shows 0 errors and 0 warnings, because all 272 non-spec any usages are gone.
- npm audit is clean.
- Yesterday's branch divergence (N-OPS1) is resolved.

Fix these first:

- 1 **A GitHub personal access token is in git history, at the tip of two pushed branches, and was served in the public GitHub Pages bundle from June to August 2026 (BUG-0001).** Revoke it today.
- 2 **Opening the simple /chart page wipes the user's saved drawings for that symbol on the backend (BUG-0002).**
- 3 **A debounced auto-save can write one symbol's drawings over another's (BUG-0003).**
- 4 **The backend watchlist IDOR (N-SEC1) is still open.** Every logged-in user can still read every other user's watchlist.

Severity	Count
Critical	1
High	2
Medium	3
Low	9

Two features are also proposed (FEAT-0001, FEAT-0002). Findings carried over from yesterday keep their old IDs and are listed under "Status of previous findings". They are not counted in the table above.

Scope

- **Repository / branch / commit:** MyTradingBox / main / 01dde7f. The working tree is not clean: an uncommitted 0.2.55 deploy bump is pending (see BUG-0006).
- **Stack:**
 - Angular 22.2.1 SPA in TypeScript 6.0.3, with NgRx 22 and Vitest 4.1.
 - Deployed to GitHub Pages.
 - About 30,000 lines of non-spec TypeScript in 148 files.
 - Angular 22 makes OnPush the default change detection; the old Default is called Eager.
 - The bundled rules cover C#, React and Delphi, not Angular. The React/TypeScript rules (RE-*) were applied where they carry over: leaks and cleanup, async errors, state mutation, races, token storage, XSS and secrets. Angular-specific concerns were added on top: change detection, RxJS cleanup and guards.

- **Covered:**
- Every non-spec source file changed in 7ca4e17...HEAD, read in full: drawing tools, chart settings and persistence, divergence caching, the 1m timeframe, crosshair, MCB, network status, and the panel removal.
- A security sweep of all of src/, public/, scripts/, CI and the full git history of all refs.
- A re-check of every open finding from the 1352 report.
- The backend UserSymbolsController (API repo), for N-SEC1.
- The rest of the codebase was sampled, not read line by line.
- **Commands run:**
- npm run test:coverage: 68 files and 928 tests, all passing. Coverage: statements 59.7%, branches 49.1%, functions 61.8%, lines 61.2%.
- npm run lint: 0 errors, 0 warnings.
- ng build --configuration production: OK, 484 kB initial / 130.7 kB transfer.
- npm audit: 0 vulnerabilities.
- **Excluded:** node_modules/, dist/, coverage/, public/ static assets, package-lock.json. There is no .audit.yml.

Findings

BUG-0001 · Critical · GitHub PAT leaked in git history, two live branches and the published bundle

- **Rule:** RE-R6 (no secrets in client code)
- **Location:**
- src/environments/environment.ts:14, src/environments/environment.prod.ts:14 and docs/githubbot.md:1, at the tip of origin/eslint-branch and origin/07-2026wip.
- gh-pages history: 0d4a9eb (2026-04-08) through 3a53598 (2026-08-20).
- **Evidence:**

```
// origin/07-2026wip:src/environments/environment.prod.ts
github: { owner: 'MyTradingViewBV', repo: 'MyTradingBox', token: 'github_pat_11CB0FRQQ0d5...' }
```

git log --all -S github_pat_ finds it in 10+ commits. It was added in d0e2dc6, the old browser-side "GitHub feedback" feature. It was removed from main in 0aa8010 and from the docs in d9d8da0, but it was never purged from history. The minified bundle on gh-pages contained token:"github_pat_..." from about 2026-06-14 to 2026-08-20.

- **Impact:**
- Anyone who loaded the live site in that period got the token in plain JavaScript.
- Anyone who can read the repo can still get it from history.
- At minimum it can create issues in MyTradingViewBV/MyTradingBox. If it has contents:write, it can push to gh-pages. That means arbitrary script on the app's origin, which can read the stored 60-hour JWT.
- Yesterday's audits missed it because they only scanned the working tree. The CI gitleaks job only scans the push range on main.
- Whether the token has already been revoked could not be checked.
- **Fix:**
- Revoke the token now (GitHub → Settings → Developer settings → Fine-grained tokens) and check the org audit log for its use.
- Delete or scrub origin/eslint-branch and origin/07-2026wip.

- Purge the token from every ref, including `gh-pages`, with `git filter-repo --replace-text`, then force-push.
- Ask GitHub Support to drop cached views.
- Prevent a repeat: see FEAT-0001.
- **Already fine:** the current feedback flow (`github-issue.service.ts:18-21`) posts to the backend. There is no token in `src/`.

BUG-0002 · High · Opening `/chart` deletes the user's saved drawings for that symbol

- **Rule:** RE-R8 / data loss
- **Location:**
 - `src/app/components/chart/chart-component.ts:94-97`
 - `src/app/components/chart/chart-base.component.ts:936-948` (auto-save)
 - `modules/shared/services/http/chart.service.ts:589` (`saveChartState`)
- **Evidence:**

```
// chart-component.ts – simple chart deliberately starts without drawings
override loadChartStateForCurrentContext(): void {
  this.drawingTools.setDrawings([]); // new [] reference → emits
  this.enforceSimpleChartDefaults();
}

// chart-base.component.ts – inherited, not overridden
this.drawingTools.drawings
  .pipe(debounceTime(1500), distinctUntilChanged(), takeUntil(this.destroy$))
  .subscribe(() => { if (!this._restoringChartState) this.saveCurrentChartState(); });
```

- **Impact:**
 - About 1.5 s after `/chart/BTCUSDT` opens, the page sends `PUT api/ChartState` with `Drawings: "[]"`.
 - Chart state is keyed on user, exchange and symbol, without timeframe. It is the same record `/mcb-chart` uses.
 - So visiting the simple chart wipes every drawing the user made for that symbol on the MCB chart.
 - Commit `01dde7f` made this page the main `/chart` route (it was `/chart-v3`). The footer "simple chart" button now triggers it.
- **Fix:**
 - Add override `saveCurrentChartState(): void {}` in `ChartComponent`.
 - Or, cleaner: add a protected `readonly persistsDrawings = false` flag that skips the auto-save subscription in the base class.
 - Add a spec asserting that `ChartComponent` never calls `saveChartState`.

BUG-0003 · High · Debounced auto-save can store one symbol's drawings under another symbol

- **Rule:** RE-R9 (races on fast-changing inputs)
- **Location:** `chart-base.component.ts`
 - `:936-948` (auto-save)
 - `:4698-4714` (`saveCurrentChartState` reads `selectedSymbol` when it fires)
 - `:4730-4737` (restore)
- **Evidence:**

```
this._restoringChartState = true;
try { this.drawingTools.setDrawings(state.drawings ?? []); }
finally { this._restoringChartState = false; } // already false when the 1.5 s debounce fires
```

- **Impact:**
- The `_restoringChartState` guard is only true while the restore runs synchronously, so it never blocks the debounced save. Every restore is written straight back.
- Drawings are only replaced when the new symbol's state arrives.
- **Race:** symbol A's state loads, then the user switches to B within 1.5 s, and B's load is slower than the remaining debounce. The save then fires with `selectedSymbol = B` and A's drawings, and **overwrites B's drawings**.
- Fast symbol switching is normal use in a trading app. The bug existed before this range.
- **Fix:**
- Capture the context at emit time and drop stale saves: ```ts drawings.pipe(map(d => ({ d, key: this.contextKey() })), debounceTime(1500), filter(x => x.key === this.contextKey())) ```
- Skip emissions whose array reference equals the one just restored.
- Clear the drawings or pause saving on `selectionChanged$`.

BUG-0004 • Medium • Security-fix commit subjects are published in the live release notes

- **Rule:** information disclosure; carries over N-OPS3, which has now happened
- **Location:** `scripts/generate-release-notes-mock.js:75`, `src/assets/release-notes.mock.json:93,97,101`, live on gh-pages
- **Evidence:** the public release notes contain "Revoke session...", "Add Content-Security-Policy..." and "Remove hardcoded fallback user ID...". The filter only hides test, docs, chore, build, ci and style commits.
- **Impact:** this tells visitors which weaknesses existed and roughly when they were fixed. It matters more now, because the backend half of the watchlist leak (N-SEC1) is still open.
- **Fix:** remove those three entries and redeploy. Hide `fix(security)` and `(auth)` scopes plus an opt-out marker like `[no-notes]` in the generator, or curate the notes by hand.

BUG-0005 • Medium • Divergence cache can hide the newest bar; out-of-order responses can overwrite newer ones

- **Rule:** RE-R9
- **Location:** `chart-base.component.ts:4258-4262` (`divergencesCacheFresh`), `:2442-2451` (`scheduleSignalOverlayRefresh`)
- **Evidence:**
- The cache counts as fresh while `baseData[last].x === _divergencesRange.lastX`.
- The bot writes divergences for the bar that just closed about 20 s after the next bar opens (`SIGNAL_REFRESH_DELAY_MS`).
- The refresh timer returns early when `showDivergences` is false.
- **Impact:**
- Turn divergences on within those 20 s, off, then on again: the cache is reused and the newest divergence is missing until the next bar opens.
- Divergence loads are also never cancelled within one selection. A toggle request and a refresh request can finish out of order, and the older response overwrites the newer one.
- **Fix:**
- Store `fetchedAt` and treat the cache as stale if `fetchedAt < lastX + SIGNAL_REFRESH_DELAY_MS`. Alternatively, set `_divergencesRange = null` when the refresh fires while divergences are hidden.

- Route loads through a `Subject` with `switchMap`.

BUG-0006 · Medium · An interrupted deploy left a half-written 0.2.55 release in the working tree

- **Rule:** deploy integrity; carries over N-OPS2, which is now happening
- **Location:** `package.json`, `src/assets/version.json`, `src/assets/release-notes.mock.json`, `updates/RELEASE_LOG.md:435-441` (all uncommitted)
- **Evidence:**
 - `RELEASE_LOG.md` records `Version: 0.2.55` and `LAST_DEPLOY_COMMIT=01dde7f...`, logged at 10:56:57 today.
 - `git ls-remote origin gh-pages` is still at `3f3a075` (2026-10-06 19:14, version 0.2.54).
- **Impact:**
 - The release log claims a deploy that never reached GitHub Pages.
 - The dirty tree will fail the next deploy's clean-tree gate.
 - Running the deploy again will bump to 0.2.56 and skip 0.2.55.
 - The deploy order (`set-version` → `log-deploy` → `build` → `publish`) is still not atomic.
- **Fix:**
 - Now: either finish the deploy and commit the four files, or revert them with `git restore`.
 - Structurally: build and publish first, then write the version, log and notes, or roll them back on failure. See FEAT-0002.

BUG-0007 · Low · Development environment points at the production API again (S6 regression)

- **Rule:** RE-R6-adjacent / environment hygiene
- **Location:** `src/environments/environment.ts:6-7`
- **Evidence:**

```
//apiUrl: 'https://localhost:7212/',
apiUrl: 'https://mytradingbox.com/',
```

This was switched back in `01dde7f`; yesterday's report marked S6 as fixed.

- **Impact:** production builds are not affected, because `fileReplacements` swaps in `environment.prod.ts`. But `ng serve`, development builds and debug-only code paths (for example `login-api.service.ts:120-130`) run against production data with real credentials.
- **Fix:** restore localhost. Better, add a `local` configuration with its own environment file so nobody switches it by editing comments.

BUG-0008 · Low · Delete/Esc key handler leaves the OnPush /mcb-chart view stale

- **Rule:** Angular change detection (OnPush default in v22)
- **Location:** `chart-base.component.ts:1052-1072` (a document `keydown` listener), `market-cipher-b-chart.component.ts:93` (OnPush)
- **Impact:**
 - After Delete removes a drawing, the rail's drawing list and its "Selectie" lock/delete section keep showing it until the next template event.
 - After Escape, the active-tool highlight and the hint stay stale in the same way.
- **Fix:** call `this.cdr.markForCheck()` at the end of the handler whenever it changed state.

BUG-0009 · Low · Locked drawings can still be deleted

- **Location:** the Delete key handler (`chart-base.component.ts:1063-1068`), `DrawingToolboxComponent.removeDrawing`, `DrawingToolsService.removeDrawing`
- **Impact:**
- A click can select a locked drawing (`selectLockedOrClear`).
- Backspace or Delete then removes it, even with "lock all" on, because none of the three delete paths checks `isLocked()`.
- **Fix:** if locking should protect against deletion, add `if (this.drawingTools.isLocked(d)) return;` to the key handler and disable the delete button for locked drawings. If it should not, document that locking only blocks moving.

FEAT-0001 · Suggested feature · CI on every branch, with a full-history secret scan

- **Location:** `.github/workflows/ci.yml:3-7, 37-50`
- **Why:**
- CI only runs on `main`, so the branches that still carry the PAT (BUG-0001) were never scanned.
- `gitleaks` only scans the push range.
- This carries over N-OPS5, which also notes that `docs:check` never receives `GITHUB_EVENT_BEFORE`.
- **Proposal:**
- Trigger CI on all branches plus `workflow_dispatch`.
- Add a scheduled job: `gitleaks git --log-opts="--all"`.
- Pass `GITHUB_EVENT_BEFORE: ${github.event.before}`.
- Add a concurrency group.

FEAT-0002 · Suggested feature · Safe, atomic deploy

- **Location:** `package.json:19` (deploy script), `scripts/predeploy-check.js`, `set-version.js`, `log-deploy.js`
- **Why:**
- BUG-0006 shows a failed deploy leaving the repo inconsistent.
- The ancestor and version guard proposed after N-OPS1 was never added.
- `angular-cli-ghpages` is still unpinned (N-SEC8).
- `version.json` (0.1.214) and `package.json` (0.2.55) are still bumped separately (N-OPS4).
- **Proposal:**
- Pin `angular-cli-ghpages` as a devDependency and call it with `npx --no-install`.
- Before deploying, check that the previous `LAST_DEPLOY_COMMIT` is an ancestor of HEAD and that the version increases.
- Derive `version.json` from `package.json`.
- Bump, build, publish, then log and commit, or revert the bump on failure.

FB-0001 · Low · Lock in the any cleanup and today's coverage

- **Rule:** RE-O1
- **Location:** `eslint.config.js:27`, `package.json:16`, `angular.json:124-129`
- **Evidence:**
- Non-spec `any` usage went from 272 to 0 (37e556e), but `no-explicit-any` is still only `warn`.
- `lint` has no `--max-warnings`.

- Coverage thresholds are still 45/30/47/46 against actual 59.7/49.1/61.8/61.2.
- **Suggestion:** make `no-explicit-any` an error, add `--max-warnings 0`, and raise the thresholds to about 58/47/60/59. This carries over N-CQ6.

FB-0002 · Low · Commit messages don't match their contents

- **Location:** 01dde7f, 37e556e
- **Evidence:**
- 01dde7f "remove web orders panel component and its styles" actually deletes web-chart, tv-chart, chart-v3, the order-metrics pipes and the panel: 2,972 lines across 41 files. It also renames routes and points the dev environment at production (BUG-0007).
- 37e556e "feat(network): ..." also removes every `any` in the codebase.
- **Suggestion:** split unrelated changes into separate commits, or at least describe them. Release notes are generated from commit subjects, and reviewers and auditors rely on them. The BUG-0007 regression went unnoticed this way.

FB-0003 · Low · `chart-base.component.ts` keeps growing

- **Rule:** RE-O6
- **Location:** `src/app/components/chart/chart-base.component.ts` (4,744 lines, up from 4,469 yesterday; 38 empty catch blocks)
- **Suggestion:**
- Extract chart-state persistence (load, save, auto-save) into its own service first. That is also where BUG-0002 and BUG-0003 live, so the fix and the extraction can go together.
- Then extract divergence loading and caching (BUG-0005).
- This carries over Q2.

FB-0004 · Low · Saved Fibonacci drawings don't get the new 0.886 level

- **Location:** `src/app/components/chart/services/drawing-tools.service.ts:332-334`
- **Suggestion:** new drawings copy the default levels into the persisted `fibLevels`, so older drawings never get 0.886. Merge in missing default levels when drawings load, or store only user overrides.

FB-0005 · Low · Push payload `icon` / badge URLs are not restricted

- **Location:** `src/custom-sw.js:154-168`
- **Suggestion:**
- `toAbsoluteUrl()` accepts any `http(s)` URL from the payload. Only the VAPID key holder can send pushes, so this amounts to a third-party image fetch at worst.
- Run `icon` and `badge` through a same-origin check, like `toSafeAppUrl` already does for click targets.

FB-0006 · Low · Stale leftovers after the chart-page removal

- **Location:** `docs/DOCUMENTATION_STATUS.md:11` (still lists "Chart-v3"), `chart-component.ts:21` (storage key `'chartV3.showDivergences'`)
- **Suggestion:** update the doc. Keep the storage key as is: renaming it would reset users' preference. Add a comment explaining why it is still named this way.

Status of previous findings

Re-checked against 01dde7f. Items marked Fixed in the 1352 report and still fixed are not repeated.

ID	Finding	Status today	Evidence
N-SEC1	Backend watchlist IDOR	Still open (High)	API/BotAPI/Controllers/UserSymbolsController.cs:339-348 still filters on the userId from the URL, with no owner or admin check. The file has not changed since 2026-04-05.
N-OPS1	Branch divergence vs live	Fixed	improve-chart and fix-audit are both ancestors of main. The live site is 0.2.54 = HEAD~1. The proposed guard was not added (FEAT-0002).
N-OPS3	Security subjects in release notes	Happened	See BUG-0004
N-OPS2	Non-atomic deploy	Happening	See BUG-0006, FEAT-0002
S6	Dev environment uses prod API	Regressed	See BUG-0007
N-CQ1	/tv-chart accidentally OnPush	No longer applicable	The component was deleted in 01dde7f. /tv-chart now redirects to /mcb-chart.
Q3	any usage	Fixed (not locked in)	272 → 0. See FB-0001.
Q2	Chart god class	Worse	4,744 lines. See FB-0003.
N-CQ2	add-symbol ticker/interval leak	Still open (Medium)	add-symbol.component.ts:174-180, 213-222
N-CQ3 / Q9	Empty catch blocks	Improved	95 → 76
N-CQ4	Dead code	Partially fixed	getSymbolIcon() (chart-base:650), watchlist delegates (:1102-1133) and capacitor-offline.service.ts remain
N-CQ5	Duplicated helpers	Partially fixed	resolveIconUrl still exists 3 times
N-CQ6	Gains not locked in	Still open	See FB-0001
N-CQ7	Allocating getters	Partially fixed	chart-base :3827, 4016, 4613
N-CQ9	API-URL conventions	Partially fixed	No + 'api/...' left. heartbeat.service.ts:31 lacks the api/ prefix.
N-CQ10	.toPromise(), static cache	Still open	admin.component.ts:279, version.service.ts:24, 42, watchlist.ts:210
N-CQ8, N-CQ11	Readonly inputs, ungated console	Still open	100 ungated console.* calls
N-SEC2 – N-SEC10	Shared origin, clickjacking, localhost in CSP, 'unknown-user', logout limits, interceptor prefix check, unpinned publish tool, ?? 1, unencoded URLs	Still open	Unchanged. chart.service.ts:562, 607; token.interceptor.ts:46; index.html:16; package.json:19
N-OPS4	Two version numbers	Partially fixed	Login shows version.json. The versions still drift (0.2.55 vs 0.1.214). The #{Build.BuildNumber}# token is still in environment*.ts:5.
N-OPS5 – N-OPS11, O1, O3–O7, D3, S1–S3, S7, S8, Q4–Q8	Ops, docs and architecture items	Still open / partially fixed	No material change. Q8: direct localStorage calls 14 → 7. O5: origin/main is now current.

Areas without findings

- **XSS sinks:** no innerHTML, bypassSecurityTrust*, document.write, eval or new Function in src/. Drawing labels are canvas fillText with numbers only.

- **Navigation and URLs:** no open redirects, `window.open` or `javascript:` URLs. `[href]` is fixed-prefix with encoded values and `rel="noopener noreferrer"`.
- **Service worker:** `notificationclick` only allows same-origin URLs. `ngsw-config.json` caches only CoinGecko and no authenticated API responses.
- **Persistence meta-reducer:**
 - The keys are versioned, and corrupt JSON is removed.
 - Fields go through an allow-list, and there is no prototype-pollution path.
 - No refresh token or PII is stored.
- **NgRx reducers (settings, key zones):** immutable updates. Flags for unavailable timeframes are kept.
- **1m timeframe:** bucket, countdown, aggregator, MCB fallback and key-zone label math all tell `1m` and `1M` apart.
- **Candle countdown:** runs outside the zone, is cleared on destroy, and only re-renders when the text changes.
- **Pen and rectangle tools:** touch and mouse lifecycles are complete. Locked drawings cannot be moved or resized.
- **WebSockets:** `wss://` public market streams only, and no credentials are sent.
- **Route guards:** every feature route has `AuthGuard`, and admin routes fail closed.
- **Deploy scripts:** no command injection. `execSync` only interpolates a hex-validated hash.
- **Removal of the web orders panel / web-chart / tv-chart / chart-v3:** no dangling imports, routes, specs or `i18n` keys.
- **Dependencies:** `npm audit` reports 0.

Recommended next steps

- 1 **Today:** revoke the GitHub PAT and purge it from all refs (BUG-0001). Resolve the half-written 0.2.55 deploy (BUG-0006).
- 2 **Before the next deploy:**
- 3 Stop `/chart` from saving drawings (BUG-0002), and make the auto-save context-safe (BUG-0003), each with a regression spec.
- 4 Remove the security subjects from the release notes (BUG-0004).
- 5 Restore the local API in `environment.ts` (BUG-0007).
- 6 **API repo:** scope `UserSymbols/{userId}/profile` to the caller (N-SEC1). It has been open for two audits.
- 7 **This week:**
- 8 BUG-0005, BUG-0008, BUG-0009.
- 9 N-CQ2 (add-symbol leak).
- 10 FEAT-0001 (CI on all branches with a history scan).
- 11 FB-0001 (lock in zero `any` and the coverage thresholds).
- 12 **Plan:** FEAT-0002 (atomic deploy), then FB-0003 (extract chart-state persistence from chart-base), then the remaining feedback items as files are touched.